

Table of Contents

- 1. Purpose and scope
- 2. System overview
- 3. Security categorization rationale
- 4. System boundary and dependencies
- 5. Key data flows
- 6. Roles and responsibilities
- 7. Selected control implementation summary
- 8. Inherited controls and dependencies
- 9. Open issues carried into later artifacts
- 10. Limitations and next artifact linkage

[Top](#) | [Bottom](#) | [TOC](#)

TRACER System Security Plan Case Study

Fictional RMF-aligned system documentation prepared for portfolio review

Prepared by **Mallory Davis**

System name	TRACER - Training Records and Compliance Evidence Repository
Fictional organization	Arclight Mission Systems
Prepared by	Mallory Davis
Portfolio purpose	Demonstrate system context, boundary reasoning, selected control implementation, and documented assumptions used in later assessment and risk artifacts.
Status	Fictional portfolio work sample. Not an operational system security plan.

Core judgment: An SSP is useful when it makes the system understandable enough to assess. This case study documents what the system does, what it touches, which controls matter most, and where open issues remain.

1. Purpose and scope [Back to TOC](#)

TRACER is a fictional internal application used by Arclight Mission Systems to maintain training completion records, role certification status, and compliance evidence used by federal program support teams. This plan defines the security-relevant system context used by the rest of the TRACER portfolio package.

The document focuses on the information needed to support control assessment, risk assessment, and remediation planning. It is not a complete authorization package and does not represent an agency submission.

2. System overview Back to TOC

Element	Description
Business Function	Tracks workforce training status, evidence artifacts, and completion attestations needed for internal readiness reporting.
Primary Users	Compliance coordinators, program managers, HR operations partners, and limited system administrators.
Data Handled	Employee name, work email, job role, training status, due dates, completion records, and uploaded support evidence.
Hosting Model	Fictional cloud-hosted web application within Arclight enterprise services.
Authentication Model	Enterprise SSO for standard users; privileged administrative access requires a stronger approval and authentication process.

3. Security categorization rationale Back to TOC

Security objective	Impact level	Rationale
Confidentiality	Low	The system stores limited workforce and training data. Disclosure could cause inconvenience and privacy concerns, but the case study does not assume highly sensitive mission data.
Integrity	Moderate	Incorrect training or compliance evidence could affect access readiness decisions, audit responses, and management reporting.
Availability	Low	A short outage would delay reporting but would not stop core operations. Manual tracking could support temporary continuity.
Overall	Moderate	The integrity impact drives the system risk posture and supports focused attention on evidence accuracy, control enforcement, and remediation tracking.

4. System boundary and dependencies Back to TOC

Component	Boundary status	Security relevance
TRACER Web Application	Inside boundary	User interface and role-based access enforcement.
TRACER Application Database	Inside boundary	Stores training records and evidence metadata.
Administrative Console	Inside boundary	Privileged configuration and account management path.
Enterprise SSO Service	Dependency	Provides primary authentication and standard user MFA.
Central Logging Platform	Dependency	Receives audit events for review and alerting.
Ticketing System	Dependency	Maintains access requests, approvals, change records, and remediation evidence.

5. Key data flows Back to TOC

- HR operations data identifies active workers and role changes that affect system access.
- Training completion records flow into TRACER through approved import files or controlled administrative entry.
- Program managers review readiness dashboards and limited exported reports.
- Audit logs are sent to a centralized monitoring platform for retention and review.
- Evidence files and corrective action artifacts are linked to compliance records when needed.

6. Roles and responsibilities Back to TOC

Role	Security responsibility
System Owner	Sets system priorities, funds remediation, approves risk decisions requiring business acceptance.
GRC or ISSO Support	Maintains system security documentation, coordinates evidence, tracks findings, and escalates open risk items.
System Administrator	Implements configuration changes, manages privileged access tasks, supports technical evidence collection.
Compliance Coordinator	Validates training record accuracy, identifies data exceptions, confirms business workflow requirements.
Program Manager	Uses reporting outputs and provides business impact input for risk treatment decisions.

7. Selected control implementation summary Back to TOC

Control area	Implementation summary	Known issue or assessment focus
Account Management	Access requests require ticket approval. Terminations and role changes are intended to trigger account review.	Assessment should verify timeliness and evidence traceability for access changes.
Least Privilege	Role groups separate system administration, compliance editing, report viewing, and read-only review.	Assessment should verify privileged roles remain limited and reviewed.
Authentication	Enterprise SSO enforces MFA for standard users. Privileged console access requires stronger documentation of break-glass use.	Open item P-01 addresses privileged break-glass access controls.
Audit Review	Authentication, export, account, and configuration events are logged centrally.	Open item P-02 addresses inconsistent evidence of routine review.
Vulnerability Management	Monthly scanning is expected and security findings should be tracked to closure.	Open item P-03 addresses aged high findings and escalation gaps.

Control area	Implementation summary	Known issue or assessment focus
Incident Response Readiness	TRACER is covered by enterprise response procedures and periodic tabletop activity.	Open item P-04 addresses action-item closure after exercise results.

8. Inherited controls and dependencies Back to TOC

Dependency	Assumed support	Boundary note
Enterprise SSO	Standard authentication, MFA, account identity source.	TRACER relies on enterprise service evidence where appropriate.
Central Logging Platform	Retention, search, alert capability.	TRACER remains responsible for producing required events.
Ticketing Workflow	Approval record, change record, remediation activity trail.	Evidence sufficiency depends on complete records, not tool existence alone.

9. Open issues carried into later artifacts Back to TOC

ID	Open issue	Related artifact
P-01	Privileged break-glass access is not supported by a consistent approval and authentication evidence package.	Controls Assessment, Risk Assessment, POA&M
P-02	Routine audit log review is defined but not evidenced with a consistent cadence.	Controls Assessment, Risk Assessment, POA&M
P-03	Two high vulnerability items are past the internal remediation target without a single escalation record.	Risk Assessment, POA&M
P-04	Tabletop action items are recorded but do not have closure criteria or completion evidence.	Controls Assessment, POA&M
P-05	Monitoring inputs are not consolidated into a recurring system posture view.	Risk Assessment, POA&M

10. Limitations and next artifact linkage Back to TOC

- This SSP case study documents selected system elements only. It does not reproduce a full control baseline or official authorization package.
- The Security Controls Assessment evaluates selected control areas described here.
- The Risk Assessment Report translates observed weaknesses into risk scenarios and treatment recommendations.
- The POA&M converts open items into trackable corrective actions with owners, dates, and closure evidence.